

Risk Assessment and Treatment Methodology

Veltrixa ApS

Document ID	ISMS-RA-001	Version	1.0
Owner	ISMS Owner	Approver	CEO
Effective date	26 July 2026	Next review	26 July 2027
Classification	Internal / Portfolio	Status	Approved for portfolio use

Portfolio note. This document is an illustrative ISMS artefact for the fictional company Veltrixa ApS. It demonstrates ISO/IEC 27001:2022 implementation logic; it is not evidence of certification or live operational performance.

1. Purpose and principles

This methodology produces consistent, valid and comparable information security risk results. Risk is assessed as the effect of uncertainty on the confidentiality, integrity or availability of information and supporting services.

2. Roles and frequency

Role	Responsibility
ISMS Owner	Facilitates assessment, maintains criteria and challenges consistency.
Risk owner	Owns the business decision, treatment and residual risk.
Asset/control owner	Provides operational evidence and implements agreed controls.
CEO	Approves risk tolerance and accepts residual risks above tolerance.

A full assessment is performed annually. Targeted reassessment is triggered by significant technical or organizational change, a major incident, a new critical supplier, material threat intelligence or a new legal or contractual obligation.

3. Assessment workflow

Step	Activity
1	Establish context. Confirm scope, assets, business processes, interested-party requirements and existing controls.

Step	Activity
2	Identify risk scenario. Record an asset or process, threat/event, vulnerability or condition, and the potential consequence.
3	Assign owner. Name the person with authority and resources to manage the risk.
4	Score inherent risk. Score impact and likelihood assuming no specific risk-reducing controls, while recognizing unavoidable characteristics of the environment.
5	Evaluate existing controls. Record control references and assess whether they are implemented and operating.
6	Score residual risk. Score impact and likelihood after existing controls.
7	Evaluate. Compare residual score with acceptance criteria and select treatment.
8	Approve and monitor. Create treatment actions, obtain required acceptance and review at the defined frequency.

4. Impact criteria

Score	Level	Illustrative consequence
1	Insignificant	Negligible operational effect; no sensitive disclosure; no contractual concern.
2	Minor	Short localized disruption or limited internal impact; readily recoverable.
3	Moderate	Material team or customer impact, limited personal-data exposure, or reportable customer issue.
4	Major	Extended service disruption, significant confidential-data exposure, major contractual or regulatory impact.
5	Severe	Existential or prolonged impact, widespread sensitive-data compromise, severe regulatory action or lasting loss of trust.

5. Likelihood criteria

Score	Level	Expected frequency / conditions
1	Rare	Exceptional; not expected within five years.
2	Unlikely	Could occur, but not expected within two to five years.
3	Possible	Plausible within one to two years or under known conditions.
4	Likely	Expected within a year or has occurred in comparable environments.
5	Almost certain	Expected repeatedly or conditions are already present.

6. Calculation and evaluation

Risk score = Impact × Likelihood. Scorers record a rationale; the number is not used without the underlying scenario and evidence.

Score	Rating	Required response
1–4	Low	May be accepted by the risk owner; monitor at least annually.
5–9	Medium	Treat or explicitly accept; review at least every six months.
10–16	High	Treatment required unless CEO accepts a time-bound exception; review quarterly.
17–25	Critical	Immediate action and executive oversight; service or change may be restricted until reduced.

7. Treatment and control selection

The available options are modify (reduce likelihood or impact), avoid (stop the activity), share (transfer part of the consequence through contract or insurance) or retain (accept). Controls are selected from Annex A and other sources as needed. The Statement of Applicability records whether every Annex A control is necessary, why it is included or excluded, implementation status and supporting document or evidence.

8. Residual risk acceptance

- Low: risk owner approval.
- Medium: risk owner approval with documented rationale and review date.
- High: CEO approval, time-bound rationale and treatment or monitoring conditions.
- Critical: not accepted for routine operation; immediate escalation and treatment are required.

9. Review and consistency

The ISMS Owner calibrates scoring across risks, challenges unsupported changes and records the date, participants and evidence used. Risk owners review treatment progress and residual ratings at the frequency required by the risk level.